

Termin 4 – Cyber-Bedrohungen und Resilienzstrategien

Prof. Dr. Dirk Loomans

29. September 2026

Vorlesungsskript • Grundlagen der Resilienz • Cyber Security Management (B.Sc.), 1. Semester • Hochschule Mainz

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Leitfrage

Gegen welche konkrete Störung soll ein System resilient sein – und welche Fähigkeit braucht es dafür?

Lernziele

Nach diesem Termin können Studierende

- Bedrohungen als Treiber von Resilenzanforderungen identifizieren (Ransomware, DDoS, Cloud-Ausfall, Identity-Ausfall, Human Failure, Supply Chain),
- Bedrohungen den vier Resilienzprinzipien zuordnen (Threat → Capability),
- konkrete technische Maßnahmen ableiten, die Funktionsfähigkeit erhalten oder wiederherstellen – nicht im Sinne von Prävention.

Fachinhalte

Resilienz ist relational

Die Sitzungen 1–3 haben Resilienz definiert, gemessen und architektonisch begründet. Nun wird derselbe Gegenstand bedrohungsgetrieben betrachtet. Ein System ist nur insofern resilient, als es gegen etwas Konkretes widerstands- oder wiederherstellungsfähig ist.

- Resilienz = Widerstand + Wiederherstellung gegen konkrete Ereignisse.
- Ohne Threat-Bezug bleiben Maßnahmen im Leeren.
- Das Mapping ermöglicht Priorisierung und Budgetfokus.
- Es ist die Grundlage für Risk-based Resilience Engineering.

Die Sitzung beantwortet nicht, wie man Angriffe verhindert, sondern wie Systeme trotz realer Ereignisse funktionsfähig bleiben oder kontrolliert zurückkehren.

Sechs Bedrohungsklassen

Die Klassen unterscheiden sich weniger in ihrer Ursache als in ihrem Wirkmechanismus. Sie konvergieren in ihren Effekten: Verlust von Verfügbarkeit, Nutzbarkeit, Steuerbarkeit oder Integrität.

1. Ransomware und destruktive Malware

Wirkprinzip: Verschlüsselung, Löschung oder Sabotage von Primärsystemen – bei lateraler Ausbreitung auch von Replikaten und Backups.

Resilienzstrategien: Immutable- oder Offline-Backups außerhalb des Blast Radius; Netzwerk- und Domain-Segmentierung; Gold-Images und Clean-Room-Recovery; Recovery-Tests statt Papierpläne.

Zielgröße: RTO und RPO niedrig halten, auch bei kompromittierter Produktion. Wiederherstellbarkeit schlägt Prävention.

2. DDoS und Lastangriffe

Wirkprinzip: Ressourcen werden schneller verbraucht, als sie bereitgestellt werden können. Der Dienst ist technisch intakt, aber nicht konsumierbar.

Resilienzstrategien: Anycast-CDN und Traffic-Scrubbing; Auto-Scaling und Rate-Limiting; Graceful Degradation; API-Quotas und Circuit Breaker.

Ziel: Der Dienst bleibt nutzbar – nicht perfekt, aber funktional. Adaptivität als Resilienzform.

3. Cloud-Provider- oder Rechenzentrumsausfall

Wirkprinzip: Die Umgebung fällt exogen aus; Redundanz auf Anbieterebene bricht weg.

Resilienzstrategien: Multi-AZ-Deployment; Cross-Region-Failover; Multi-Cloud für kritische Workloads; lokaler Fallback für Mindestfunktion; Trennung von Steuer- und Ausführungsdomäne.

Lehrsatz: Provider ≠ Resilienz – Architektur entscheidet.

4. Identity-Ausfall (IdP als SPOF)

Wirkprinzip: Systeme sind technisch verfügbar, aber nicht benutzbar (Lockout), weil Authentisierung oder Token-Ausgabe zentral blockiert ist.

Resilienzstrategien: Break-Glass-Accounts lokal und offline; zweiter unabhängiger IdP oder Fallback-Authentisierung; Notfallzugang ohne Cloud-Abhängigkeit; Minimierung globaler Koppelstellen.

Kernaussage: Identity ist oft der versteckte Single Point of Failure.

5. Human Failure und Fehlkonfiguration

Wirkprinzip: Fehler propagieren systemisch über Automatisierung (IaC, CI/CD, Admin-Fehler); aus einem lokalen Fehler wird ein systemischer.

Resilienzstrategien: Vier-Augen-Prinzip und Separation of Duties; Staging, Canary Deployment, Feature Flags; Rollback- und Snapshot-Fähigkeit; Auditierbarkeit und Post-Mortem-Kultur statt Schuldsuche.

Prinzipbezug: Wiederherstellbarkeit und Governance.

6. Supply-Chain-Angriff

Wirkprinzip: Kompromittierung kommt über Dritte in die eigene Kontrollkette (SolarWinds, Kaseya).

Resilienzstrategien: Lieferantendiversität und getrennte Source of Truth; Zero Trust for Dependencies; Offline-Verifikation und kein Auto-Push bei kritischen Komponenten; Recovery unabhängig vom kompromittierten Dependency-State.

Lehrsatz: Resilienz ist hier das Sicherheitsnetz nach dem Vertrauensbruch.

Mapping: Von der Bedrohung zum Prinzip

Bedrohung	Wirkung auf das System	Resilienzprinzip	Normativer Bezug
Ransomware	vollständiger Funktionsverlust	Wiederherstellbarkeit, Diversität (immutable/offline)	ISO/IEC 27031, BSI 200-4
DDoS / Last	Degradation statt Zerstörung	Adaptivität (Autoscale, Graceful Degradation)	ENISA DDoS Guidance
Cloud-/RZ-Ausfall	infrastrukturelle Nichtverfügbarkeit	Redundanz (Multi-AZ/Region)	NIST SP 800-160 Vol. 2
Identity-Ausfall	Nutzungsunfähigkeit trotz intakter Systeme	Diversität und Recovery, Break-Glass	NIST CSF, Zero Trust
Human Failure	ungewollte Fehlpropagation	Rollback, Wiederherstellbarkeit, SoD	BSI 200-4, IT-Grundschutz
Supply Chain	importierter externer Fehler	Diversität und Isolation, Zero Trust	ENISA Supply Chain Guidance

Drei Lehren aus dem Mapping:

- Die Bedrohung entscheidet nicht über das Tool, sondern über das anzuwendende Prinzip.
- Verschiedene Bedrohungen können dasselbe Prinzip adressieren (Ransomware und Human Failure → Recovery).
- Dasselbe Prinzip wirkt gegen sehr verschiedene Bedrohungen (Diversität gegen Identity-Ausfall und Supply Chain).

Nicht die Bedrohung wird kontrolliert, sondern die Fähigkeit, ihren Effekt zu absorbieren („capability-based resilience“).

Normativer Bezug

- **NIST SP 800-160 Vol. 2:** Resilienz als Menge von Fähigkeiten, die am Effekt, nicht an der Ursache ausgerichtet werden [1].
- **ISO/IEC 27031:** definierte Ziele (RTO/RPO), getestete Recovery-Fähigkeit, wiederkehrende Validierung [2].
- **BSI-Standard 200-4:** bewertet, wie wirksam Maßnahmen im Ereignisfall betrieben werden können, nicht ob sie existieren [3].
- **ENISA:** Resilienz sektorspezifisch und bedrohungsnah formuliert (Energie, Gesundheit, Finanzmarkt).

Normen bewerten Resilienz als funktionale Antwortfähigkeit auf definierte Störungstypen. Ein Threat-to-Resilience-Mapping ist damit methodisch gefordert.

Übung: Threat-to-Resilience-Mapping

Gruppenarbeit, 15–20 Minuten. Wählen Sie eine Bedrohung: Ransomware, DDoS, Cloud-/Region-Ausfall, Identity-Ausfall, Human Failure oder Supply-Chain-Angriff.

1. **Wirkmechanismus:** Wie genau führt die Bedrohung zur Funktionsbeeinträchtigung? (1–2 Sätze)
2. **Zuordnung:** Welche mindestens zwei Prinzipien sind vorrangig relevant – und warum?
3. **Maßnahmen:** Je Prinzip mindestens eine technisch realistische Maßnahme.

4. **Kurzfazit:** Ist das System danach resilient, bedingt resilient oder weiterhin fragil? Ein Satz Begründung.

Ergebnis: eine Folie oder ein Blatt mit höchstens sechs Stichpunkten; 2–3 Minuten Präsentation. Bewertet wird die Schärfe der Zuordnung, nicht die Menge der Maßnahmen.

Prüfungsrelevante Leitfragen

- Warum ist Resilienz ohne Threat-Bezug methodisch unzureichend?
- Welche Bedrohung adressiert primär das Prinzip Wiederherstellbarkeit, und warum?
- Wie unterscheidet sich das Wirkmodell eines DDoS von dem einer Ransomware, und wie spiegelt sich das im Resilienzdesign?
- Wie begründet der BSI-Standard 200-4, warum Tests wichtiger sind als Dokumente?
- Erklären Sie an einem Beispiel, warum Identity ein versteckter SPOF ist.

Kernpunkte: Resilienz bewertet sich immer gegen eine Bedrohung. Das Threat-Capability-Mapping schafft Architekturdiziplin. Dieselben vier Prinzipien greifen über Bedrohungsklassen hinweg. Hybrid erhöht Angriffsfläche und Gegenstrategieraum.

Vor- und Nachbereitung

Das [Glossar](#) enthält die Begriffe der Sitzungen 1–4 mit Rückverweisen und dient als Prüfungsorientierung.

Ausblick Termin 5: Resilienz als Organisationsfähigkeit – Rollen, Prozesse, Übungen, Governance.

Material aus dem Archiv

04 Cyber-Bedrohungen und Resilienzstrategien/04_Cyber Bedrohungen und Resilienz Strategien.pdf, Skript Sitzung 4 Grundlagen der Resilienz.pdf und Glossar Resilienz 4.0.pdf.

Bibliografie

- [1] R. Ross, V. Pillitteri, R. Graubart, D. Bodeau, und R. McQuaid, „Developing Cyber-Resilient Systems: A Systems Security Engineering Approach“, NIST Special Publication 800-160 Vol. 2 Rev. 1, Dez. 2021. doi: [10.6028/NIST.SP.800-160v2r1](https://doi.org/10.6028/NIST.SP.800-160v2r1).
- [2] „ISO/IEC 27031:2025 Cybersecurity – Information and communication technology readiness for business continuity“. [Online]. Verfügbar unter: <https://www.iso.org/standard/27031>
- [3] „BSI-Standard 200-4: Business Continuity Management“. Bonn, Mai 2023.